Zero-Downtime CI/CD Pipeline

NovaPay Digital Bank - Technology Risk Committee Presentation

Prepared by: DevOps Lead, NovaPay Digital Bank

Strictly Private and Confidential

The Problem

NovaPay's current deployment reality

- **Manual SSH deployments to production - no automation, high human-error risk**
- **3 production incidents in Q4 2025 traced to untested code deployments**
- **Deployment frequency: once every 2 weeks (industry benchmark: multiple per day)**
- **Mean Time to Recovery: 4.5 hours (target: under 15 minutes)**
- **Zero automated compliance scanning - last RBI audit flagged 17 non-conformances**
- **Zero observability - incidents detected by customers, not systems**

Why This Matters Now

Business and regulatory context

- **India's UPI infrastructure processes over 12 billion transactions per month**
- **Even a 30-second outage during peak hours can affect millions of payments**
- **RBI supervisory scrutiny increases with every unresolved non-conformance**
- **Competitors are deploying multiple times daily - NovaPay deploys twice a month**
- **The CTO has allocated a 90-day window; this architecture must be approved today**

Solution Overview

An 8-stage, compliance-native CI/CD pipeline

- **1. Source Control & Trigger - trunk-based, signed commits, branch protection**
- **2. Build & Compilation - automated tests, 80% coverage gate, SemVer**
- **3. Static Analysis (SAST) - SonarQube, 0 Critical tolerance**
- **4. Dependency & Container Scanning - Trivy, SBOM, CVE gating**
- **5. Integration & Contract Testing - Pact, isolated test environments**
- **6. Dynamic Analysis (DAST) - OWASP ZAP, OWASP Top 10 coverage**
- **7. Policy & Compliance Gates - OPA/Kyverno, RBI/PCI-DSS mapped**
- **8. Deployment & Verification - canary rollout, automated rollback**

Deployment Strategy

Canary-first, with blue-green fallback

- **Canary progression: 1-2% -> 5-10% -> 25-50% -> 100%, over ~2.5 hours with bake time**
  - Promotion between phases gated by statistical tests, not manual judgment
  - - Welch's t-test on p99 latency vs 7-day rolling baseline
  - - Chi-squared test on error rate proportions
- **Blue-green kept as fallback for emergency hotfixes requiring instant full cutover**
- **Shared database across both strategies requires backward-compatible schema changes**

Compliance Gates

6 automated gates mapped to RBI, PCI-DSS v4.0, SoD

- **SAST (SonarQube) - 0 Critical, 24h CISO exception window**
- **DAST (OWASP ZAP) - 0 Critical/High OWASP Top 10, TRC review for exceptions**
- **Dependency (Trivy) - 0 Critical CVE, 72h remediation window**
- **Licence (FOSSA) - No GPL/AGPL/SSPL, legal sign-off required**
- **Policy (OPA/Kyverno) - All K8s policies pass, dual approval override only**
- **Infra (Checkov) - No privileged containers, Tech Lead exemption only**

Segregation of Duties

Enforced technically, not just on paper

- **Developers cannot approve their own pull requests**
- **Deployment credentials are separate from any individual developer login**
- **Production deployment requires dual approval: Release Manager AND SRE Lead**
- **Every approval, override, and exception is logged immutably with timestamp**

Zero-Downtime Database Migrations

The expand-contract pattern

- **Direct schema changes break old app versions still running mid-deployment**
- **Expand: add new schema elements - both app versions remain compatible**
- **Migrate: backfill data via throttled batch jobs - safe to retry**
- **Contract: remove old schema only after 100% migration confirmed - separate, DBA-gated deployment**
- **Handles 100M+ row financial tables via 500-row batches with throttling**

Automated Rollback

Three categories, minutes not hours

- **Category A (under 60 seconds): 5xx rate, health check failures, OOM kills - zero human intervention**
- **Category B (under 15 minutes): latency/error budget breaches - alert then auto-rollback if unacknowledged**
- **Category C (manual): gradual degradation, customer reports - human judgment required**
- **Result: MTTR drops from 4.5 hours to under 60 seconds for the most common failure modes**

Observability & DORA Metrics

Systems detect problems, not customers

- **Deployment Frequency: target multiple per day (from once every 2 weeks)**
- **Lead Time for Changes: target under 2 hours (from unmeasured/manual)**
- **Change Failure Rate: target under 5%**
- **MTTR: target under 15 minutes (from 4.5 hours)**
- **Three dashboards: Engineering (real-time), Management (trends), Regulatory (audit-ready)**

Commit-to-Production Timing

Meeting the sub-2-hour target

- **Stage 1 (Source): ~1 min**
- **Stage 2 (Build): ~10 min**
- **Stages 3+4 (SAST + Dependency scan, parallel): ~8 min**
- **Stage 5 (Integration/Contract tests): ~10 min**
- **Stage 6 (DAST): ~15 min**
- **Stage 7 (Compliance gates): ~20 min**
- **Stage 8 (Canary deploy through first gate): ~40 min**
- **Total: approximately 104 minutes - within the 120-minute target**

Lessons Applied From Industry

Learning from real failures

- **Knight Capital (2012): fleet consistency verification prevents partial rollouts**
- **YES Bank (2020): synthetic transaction monitoring detects failures before customers do**
- **Cloudflare (2019): config changes go through the same pipeline as code, with canary + independent rollback**
- **SBI YONO (2023-24): deployment blackout calendar avoids known high-traffic windows**

Risk Mitigation Summary

Addressing every stakeholder's concern

- **CTO: deployment frequency and lead time both improve dramatically**
- **CISO: automated SAST/DAST/dependency scanning on every single change**
- **Head of Compliance: full audit trail, RBI/PCI-DSS mapping, exception workflows**
- **Dev Team: fast automated feedback, no manual SSH burden**
- **SRE/Ops: automated rollback reduces on-call burden and incident duration**
- **RBI Auditor: documented, enforced controls replace manual checklists**

The Ask

What we need from this committee

- **Approval to proceed with implementation within the 90-day CTO window**
- **Sign-off on the compliance gate thresholds and exception workflows presented**
- **Confirmation that this architecture satisfies the committee's regulatory readiness bar**
- **Next step: begin Phase 1 implementation (pipeline stages 1-4) within 2 weeks of approval**